

VULNERABILITY MANAGEMENT FRAMEWORK

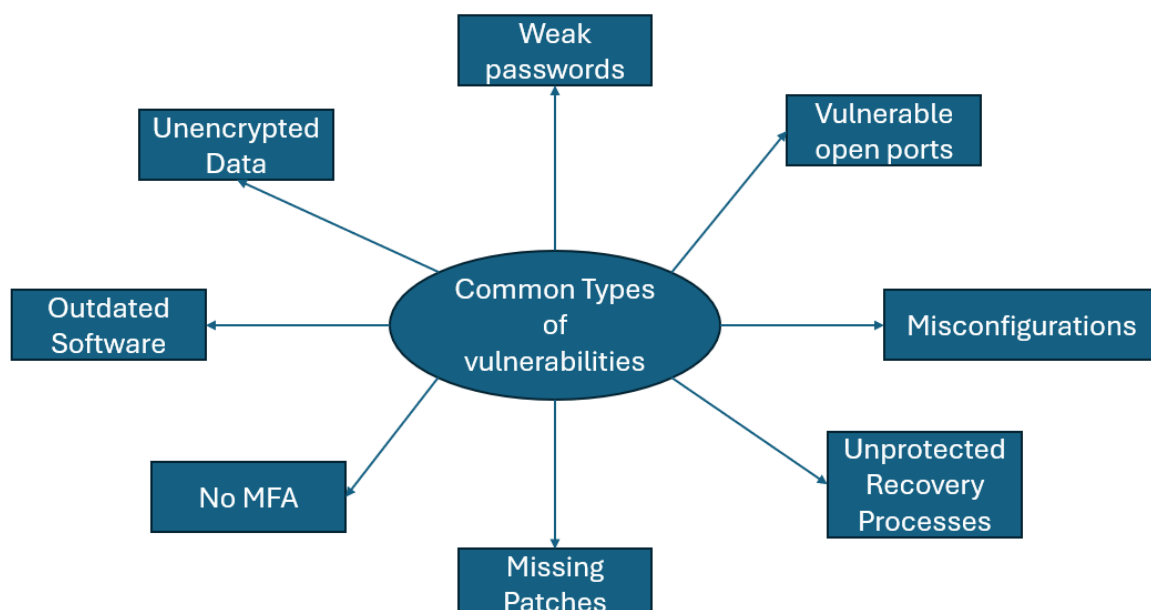
Contents

Introduction	2
Personal vulnerability management framework	3
Organisational vulnerability management framework	4

Introduction

This vulnerability management framework is designed to help users efficiently and systematically handle vulnerabilities within their systems. This framework can be used by both individuals and organisations. This framework was developed as threat actors commonly exploit known unpatched vulnerabilities within IT systems. Some common vulnerabilities include outdated software and protocols, weak passwords, vulnerable open ports and misconfigurations. This framework is split into personal and organisational usage sections as the processes for these are different. This is because organisations must comply with legal requirements and require more professional responses to vulnerabilities. While individuals do not have to comply with laws such the GDPR or Data Protection Act meaning they are able to use more lightweight structure.

This vulnerability management framework cannot allow users or organisations to find all vulnerabilities within a system as no system is perfect. However, this vulnerability management framework can increase the number of vulnerabilities discovered, patched and documented. Do not trust this vulnerability management framework blindly as it can be wrong. Ensure to adapt the framework's structure to your own security needs and compliance requirements.



The spider diagram above shows the common vulnerabilities within systems seen in both personal and organisational security. It is important to ensure that these vulnerabilities are patched and are reduced within your system where possible. This spider diagram does not show all vulnerabilities or exact misconfigurations in IT systems.

Personal vulnerability management framework

This section is made specifically for individual's users to discover, patch and document vulnerabilities within their own systems. Remember to adapt this framework to your own security needs and threat model. The structure below will use an example of finding a weak password for an account.

- The first step is to calm down
- This can be done by taking a few deep breaths or releasing anger in a non-harmful way
- The second step is discovery
- This is where you will locate the vulnerabilities within your account
- This could be done through a password review, daily security check in or just noticing the length of the password in general.
- The third step is Assessing
- This is where you will assess the priority and impact of the vulnerability
- You should ask yourself questions such as what happens if an attacker cracks the password? How easily can my threat model exploit this?
- The fourth step is Patching
- This is where you will fix the vulnerability within your account
- This can be done by changing the password to a 12-16 character generated by a password manager
- You may also turn on MFA on the account if it isn't enabled already
- Make sure to verify that the patch has been applied to the vulnerability
- The fifth step is documenting
- This is where you will document the process of discovering, assessing and patching the vulnerability
- This can be done through the structure What (Weak password) → Domain(Account security) → Why(An attacker could bypass the password to gain unauthorised access to the account) → How(The attacker could use automated tool to crack the password) → Patch(12–16-character password and MFA applied to account) → Potential improvements (What could be improved for next time in the process?)
- This documentation should be stored securely using encryption
- The final step is to repeat the process
- This repetition depends on your threat model.
- For example, for script kiddie every 1-2 months running this process should be efficient.

Organisational vulnerability management framework

This section is specifically made for organisations to discover, patch and document vulnerabilities. I would not recommend this section for individual users as this framework will include business specific actions and processes. Make sure to adapt this to organisational requirements as needed. This example will use an outdated Windows operating system on a company device.

- The first step is to identify
- This means discovering the vulnerabilities within the organisation's systems.
- This can be done through Pen testing or automated vulnerability scanning
- The second step is to evaluate
- This means assessing the impact of the vulnerability being exploited on business operations and other metrics
- This also includes prioritizing vulnerabilities which can be done through CVSS and threat modelling
- The third step is to treat the vulnerability
- This includes implementing the correct security measures to fix the vulnerability
- In this case, this can be done by applying a system update to the device and enabling automatic updates
- The fourth step is verification
- This means ensuring that the systems update has been installed with no issues
- This can also include ensuring that there are no new security updates for the Windows operating system.
- The fifth step is reporting
- This means documenting the process of discovering, assessing and patching the vulnerability
- This can be done using the structure What (Outdated Windows operating system) → Domain (Endpoint protection) → Threat model (Opportunistic attacker and competitors) → Priority (Medium) → Impact (Reputation damage, lawsuits, disruption to business operations) → Patch (Installing latest security update and enabling automatic updates)
- The final step is repeating
- This means repeating the process depending on the threat model your organisation currently has
- For example, for businesses with competitors this could be every month but adapt this as needed.